



Année universitaire 2023

Court mémoire

Présenté par

Clément WAHAGA

Stratégies de protection des données sensibles par les gouvernements

23 juin 2023

RAN Méthodologie PCA

Tuteur pédagogique à l'ACESTE-CNAM :
Dr. Linda SIMON-DESBOIS

Table des matières

I. Données sensibles et stockage de ces données.....	6
A. Définition des données sensibles.....	6
B. Les différentes formes de stockage des données sensibles	7
II. Les cyberattaques.....	8
A. Définition des cyberattaques	8
B. Les différents types de cyberattaques	10
III. Leviers de protection des données sensibles contre les cyberattaques par les gouvernements	11
A. Les normes et les réglementations	11
B. Les politiques et les stratégies	11
C. Les technologies de cybersécurité	12
Bibliographie.....	15

Introduction

A propos de l'auteur et importance de la thématique

Je me présente Clément WAHAGA, j'ai 33ans, je suis originaire de Maré, une île des Loyauté attaché à la Nouvelle-Calédonie et résident de Dumbéa commune de la Province-sud.

Je sors du collège avec mon DNB (diplôme national du brevet), puis j'entreprends des études d'électrotechnique au lycée Petro ATTITI qui se solde malheureusement par un échec. Cet ainsi que je suis entré directement dans la vie active.

J'ai effectué ma première mission professionnelle au sein des pompiers de Dumbéa en tant que guetteur (personne en charge de surveiller les débuts d'incendie), d'une durée de 3 mois. Puis j'ai eu ma première expérience en intérim où j'ai été manœuvre en VRD (terrassment et assainissement) chez Dumez, cette même entreprise voit mon potentiel et m'offre mon premier titre professionnel (Titre professionnel Constructeur Professionnel Voirie Réseaux, équivalence niveau IV).

Grace a ce diplôme, j'ai intégré la mairie de Dumbéa où je suis devenu animateur de quartier puis animateur multimédia.

Conscient des compétences que j'ai acquises, j'ai décidé de continuer sur la voie de formation professionnelle continue.

J'ai obtenu en 2021 le titre professionnel de développeur web et web mobile (équivalence niveau V).

Maintenant j'envisage un diplôme d'ingénieur du numérique en spécialité cybersécurité car j'ai intention de faire de ma passion mon métier.

Geek de passion et actuellement développeur web et web mobile cherchant une évolution entant qu'ingénieur en cybersécurité, je me questionner sur la façon dont les gouvernements protègent les données sensibles de leurs utilisateurs contre les cyberattaques.

La protection des données sensibles est un enjeu crucial dans le contexte de la digitalisation et de l'ère numérique. Ce rapport se concentre sur les mesures de protection des données sensibles contre les cyberattaques mises en place par les gouvernements.

La première partie traite de la définition des données sensibles et des différentes formes de stockage de ces données. La seconde partie se concentre sur les cyberattaques, leur définition et les différents types d'attaques. La troisième partie examine les leviers utilisés par les gouvernements pour protéger les données sensibles contre les cyberattaques. Elle aborde les normes et réglementations en place, les politiques et stratégies adoptées ainsi que les technologies de cybersécurité.

Il est important de noter que les gouvernements jouent un rôle important dans la protection des données sensibles des utilisateurs. La mise en place de mesures adéquates est essentielle pour garantir la sécurité et la confidentialité des données des utilisateurs. Ce rapport fournira une analyse factuelle et neutre des mesures prises par les gouvernements pour protéger les données sensibles contre les cyberattaques.

Glossaire des termes techniques

- **Internet** : réseaux ordinateurs interconnecter
- **Hackers** : souvent associer des criminel, les hackers peut être blanc (éthique), gris ou noir (criminel)
- **Data center** : infrastructure physique contenant des cluster ou grappe de serveur dédié au stockage de données
- **Cloud ou nuage informatique** : type de stockage en ligne répondu depuis le Web 2
- **Progiciel** : logiciel développer par une société pour ces propres besoins, logiciel interne à une société ou un organisme
- **GAFAM** : Les GAFAM (ou GAFA) sont un acronyme utilisé pour désigner les cinq plus grandes entreprises technologiques américaines : Google, Apple, Facebook, Amazon et Microsoft.
- **Vulnérabilité ou faille** : faiblesse dans le système d'information, point d'entrée
- **Darknet** : partie cachée d'internet, il se compose de sites internet qui ne peuvent pas être trouvés à l'aide des moteurs de recherche classiques.
- **Javascript** : langage de programmation coté client
- **Client/serveur** : coté client : ce que l'utilisateur perçois depuis l'interface d'un site ou d'une application, coté serveur constitue tous ce qui passe en arrière-plan à l'intérieur du site ou d'une application
- **SQL** : langage informatique servant faire des requêtes sur la base de données

I. Données sensibles et stockage de ces données

A. Définition des données sensibles

Avant de définir ce qu'est une donnée sensible, il est important de situer le contexte dans lequel elles se trouvent : Internet. (Figure 1)

Depuis l'avènement d'internet, des réseaux sociaux et de l'intelligence artificielle plus récemment, les utilisateurs sont et seront submergés d'une source infinie d'informations. Toutes ces données circulent dans le vaste réseau qu'est Internet et sont catégorisées selon les besoins et utilisation des milliards d'utilisateurs qui composent la toile. Elles sont gratuites parfois payantes, en open sources ou sous conditions d'utilisation, anonymisées ou nominatives (Priol, 2017).

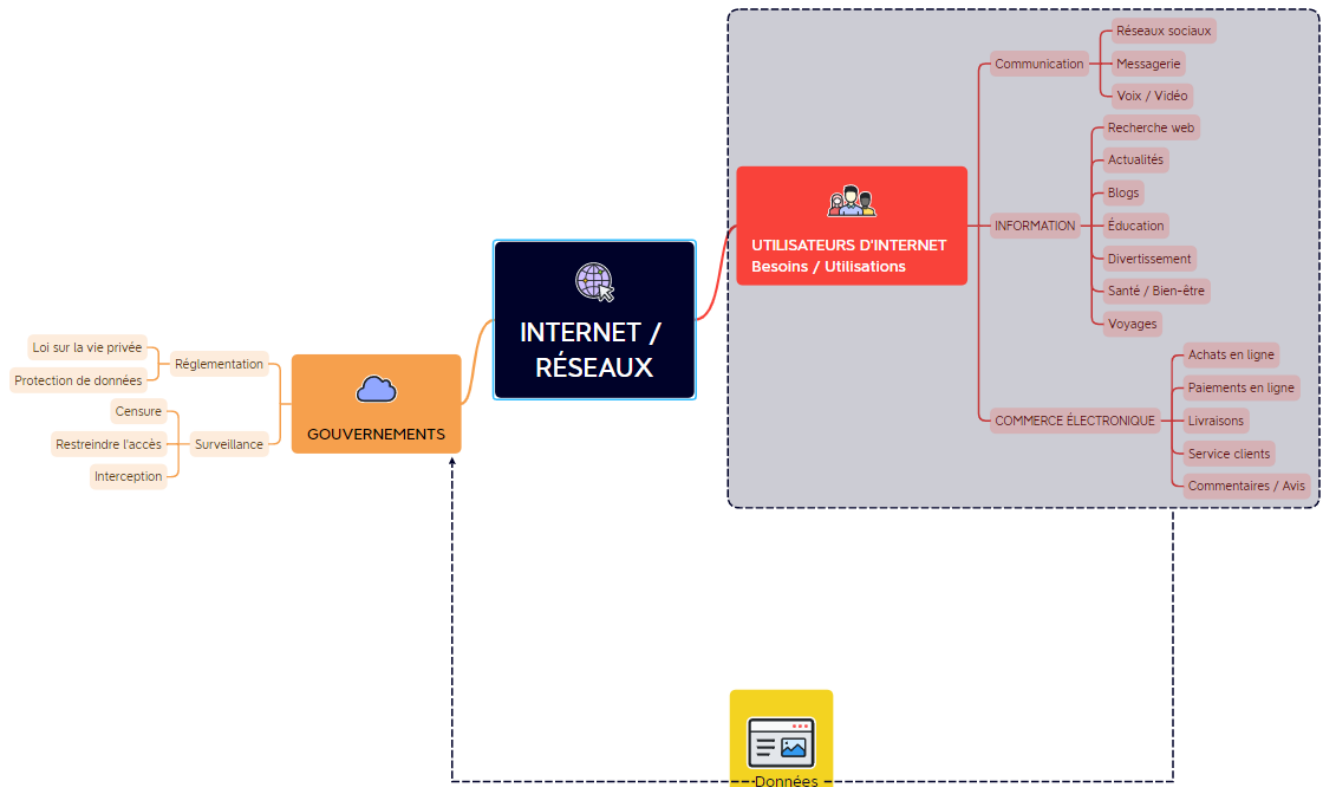


Figure 1 : Schéma de principe du fonctionnement d'internet. Carte mentale 2023, (Wahaga,2023)
internet et les différents acteurs qui la constitue

Mais qu'est-ce qu'une donnée sensible ? Pour comprendre le concept de données dites « sensibles », il faut faire la distinction entre la donnée personnelle et sensible.

Une donnée personnelle est toute information se rapportant à une personne physique identifiée ou identifiable (CNIL, 2023). Donc une donnée qui permet d'identifier une personne physique (exemple : nom, prénom) : c'est une identification directe. Il y a également l'identification indirect (exemple : n° de téléphone, une adresse, un commentaire...etc.)

La donnée dite « sensible » rassemble toutes informations concernant un individu physique et/ou moral qui permet de l'identifier indirectement, qui relèvent du domaine privé du propriétaire, données qui sont principalement convoitées par les hackers. Les données sensibles les plus courantes sont les informations bancaires, les données biométrique, les données géospatiales, les numéros de sécurité sociale, les opinions politiques et religieuses, l'origine raciale et ethnique. (RGPD,2018)

En résumé, toutes les données sensibles sont des données personnelles, mais toutes les données personnelles ne sont pas nécessairement sensibles. Les données sensibles nécessitent une protection adéquate en raison de leur nature et du risque qu'elles peuvent causer si elles sont compromises.

Mais ces données sont-elles stockées efficacement ?

B. Les différentes formes de stockage des données sensibles

Avec la multitude de données circulant chaque jour, les différents acteurs (entreprises, gouvernements, fournisseurs de service cloud) utilisent différentes formes de stockage (*Figure 2*). En perpétuelle évolution, les formes de stockage se sont adaptées au fil des années pour la protection des données contre le piratage. Associées, au silo, l'image des "silos" est particulièrement adaptée au stockage de données des usagés (Priol, 2017) Les type de stockage sont :

- Stockage sur site ou « Silos logiciel » : service de stockage en interne, progiciel ou logiciel du marché. Service propre à l'entreprise et organisation, stockage parfait pour un contrôle total des données mais nécessite des compétences et ressources à la maintenance.
- Stockage sur service cloud privé ou public :
 - Privé : Client d'un prestataire de service cloud, un stockage sécurisé et géré par des professionnels.
 - Public : les données sont stockées dans des serveurs partagés publics tels que Amazon Web Service, Google Cloud ou Microsoft Azure, plus économique que les deux types de stockage cités précédemment mais il peut poser des problèmes de sécurité car les données sont stockées dans des serveurs partagés. En utilisant la fonction de synchronisation, vous bénéficiez d'une grande protection, mais cela implique que vos données sont stockées dans le cloud, également appelé le 'nuage '. Cela signifie simplement qu'elles se trouvent sur l'ordinateur d'une autre personne, ce qui les rend potentiellement accessibles au fournisseur de services cloud, aux organismes gouvernementaux lors d'enquêtes, ainsi qu'à des personnes malveillantes ou à des hackers qui pourraient y accéder de différentes manières(Steinberg, 2019).
- Stockage hybride : combinaison des différents types cités plus haut. Si bien paramétré, il pourrait être la solution de stockage la plus sécurisée

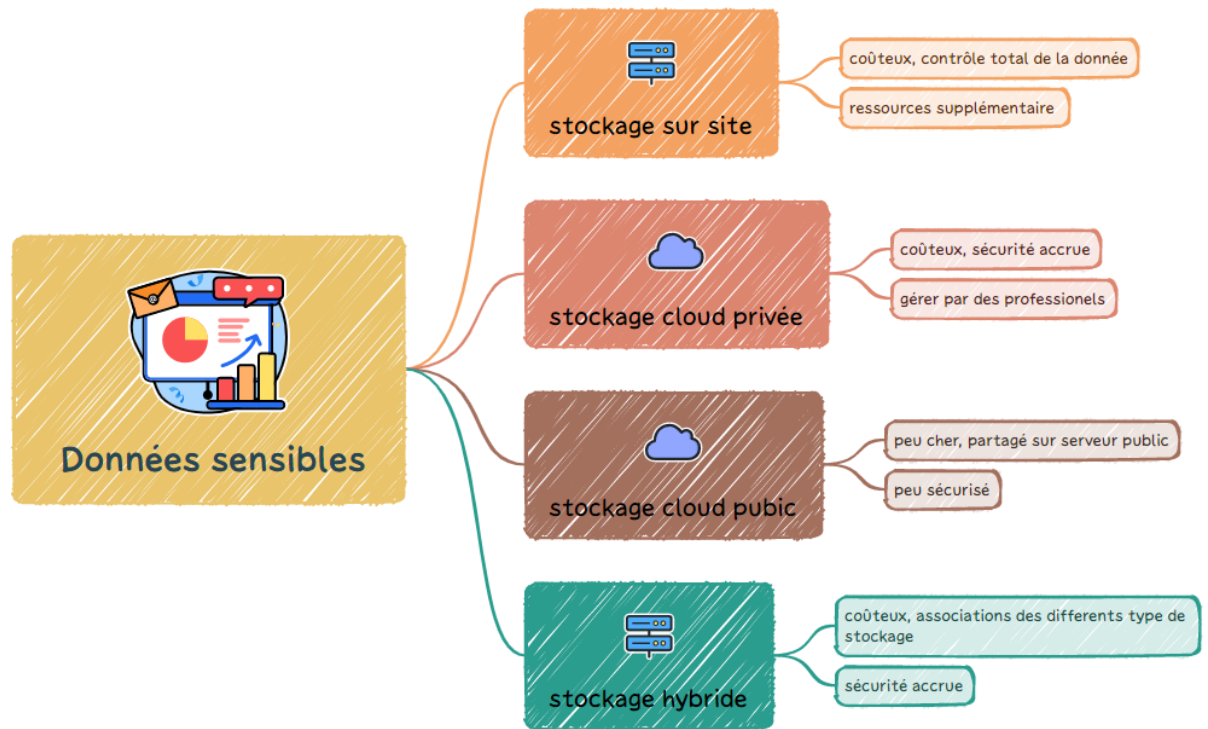


Figure 2 : schéma de principe du stockage de données de sensibles, carte mental 2023, (Wahaga, 2023)
différents types de stockage

Les données sensibles sont protégées et stockées par les entreprises, les gouvernements et les fournisseurs de services cloud afin d'assurer leur intégrité, leur sûreté et leur sécurité. Avec la quantité croissante de données échangées chaque jour, les acteurs impliqués utilisent diverses formes de stockage qui ont évolué au fil des années pour lutter contre le piratage (Dumons, 2014). Le stockage sécurisé des données sensibles est un enjeu essentiel au bon fonctionnement de l'économie planétaire mais très écocide car polluant, "Data center" ou autre équipement dédié au stockage sont très énergivore. Toutes ces données que nous envoyons et recevons ont un impact énorme sur l'environnement. Elles nécessitent une quantité importante d'énergie et de ressources naturelles. C'est une forme de pollution invisible, qui se produit lorsque nous cliquons sur le bouton 'envoyer' et que les données voyagent jusqu'à notre écran (Dumons, 2014).

Si ces données sont dites « sensibles », c'est que d'un point vu, elles sont tout à fait désignées pour être convoitées par des personnes mal vaillantes, des espions ou encore des hackers.

II. Les cyberattaques

A. Définition des cyberattaques

Les données sont très prisées des Géants web (GAFAM), des gouvernements, et entre autres des hackers, qui inventent chaque jour des techniques différentes pour les dérober, les vendre au plus offrant, ou tout simplement les échanger contre une rançon. Piratage, cyberattaque, des termes de plus en plus en vogue mais concrètement qu'est-ce qu'une cyberattaque et quelles sont ses différentes formes ?

Une cyberattaque est un acte offensif envers un système d'informations via internet.

Il existe 4 profils d'attaquant :

- Les états : les nations qui ont un budget illimité
- Les cybercriminels : cellules cyber terroristes qui offrent leurs compétences au plus offrant
- Les hacktivistes : groupe de hackers militants
- Les personnes seules : hackers opérant en solo souvent des chercheurs de failles

Le déroulement d'une attaque :

Une cyberattaque est souvent un travail de longue haleine, organisation, planification sur une longue durée, la réalisation d'une attaque dépend de la capacité de l'attaquant à obtenir toutes informations sur la cible, jugées utiles au bon déroulement de la mission, c'est la phase de reconnaissance. La récolte des informations se solde souvent par la trouvaille de vulnérabilité qui permet à l'attaquant de s'infiltrer dans le système via des outils qui aurait pu développer ou bien avoir acheter dans le Darknet c'est la phase d'armement. Via une attaque par phishing l'attaquant livrera l'exploit dans un mail frauduleux, puis il exploitera la vulnérabilité pour installer le vers ou rançongiciel qui lui permettra de prendre le contrôle du système d'informations pour y insérer un code malicieux qui se résultera par un chiffrement des données puis enverra une rançon au propriétaire qui devra payer pour récupérer ses données ou il y aura destruction (figure 3) (CLARHAUT, 2015).

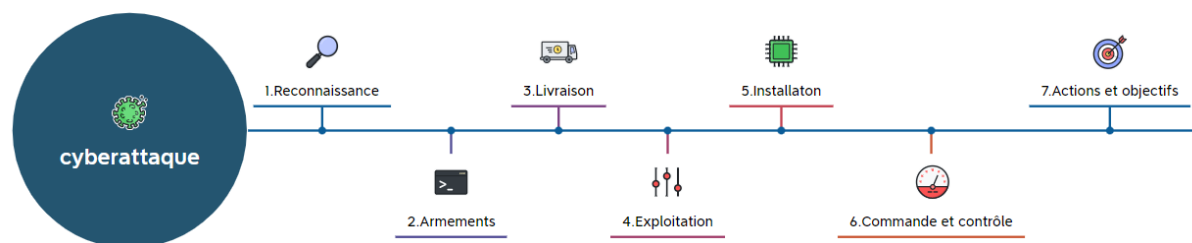


Figure 3 : déroulement d'une cyberattaque du type ransomware, carte mental 2023, (Wahaga,2023)
différentes phases d'une cyberattaque. 1. phase de reconnaissance enquête sur la cible, 2. obtention ou développement des outils, 3. étape de livraison : attaque par phishing, 4. Exploitation de la vulnérabilité, 5. installation des différent vers informatique, 6. Action des vers informatique : chiffrement des données, 7. Envoie de la rançon au propriétaire fin de l'attaque

Donc une attaque informatique visant à détruire une infrastructure physique ou informatique ou à dérober des données par une personne tiers ou un groupe de personne voire un état. La première cyberattaque de l'histoire visait à détruire un gazoduc canadien. Plus récemment, une cyberattaque étatique visait à infecter d'un cheval de Troie les téléphones mobiles de personnes publiques pour subtiliser toutes données, ex : le logiciel espion : Pegasus est reconnu pour sa force de frappe tactique, le groupe de hackers « Anonymous » connu pour leur implication dans les mouvements sociaux tels que le piratage d'une église de scientologie en 2010 et plus récemment le mouvement Black Lives Matter. Des acteurs différents qui utilisent les cyberattaques comme une arme ou encore comme un moyen d'expression. Le fond reste le même mais la forme est très souvent différente (Arte, 2023).

B. Les différents types de cyberattaques

Il existe un nombre impressionnant de cyberattaques, cette partie du rapport fournira un récit détaillé des cyberattaques qui a pour résultante la subtilisation, le contrôle et la destruction de données.

Attaques coté client :

- Attaques par failles XSS et CSRF token : attaque qui consiste à injecter le code javascript dans le navigateur (compromission des données authentification). L'attaque CSRF est une technique malveillante qui consiste à subtiliser un cookie d'un utilisateur tiers pour prendre le contrôle de sa session (CLARHAUT, 2015).
- Attaques par injection SQL : L'attaque par injection SQL ou SQLI consiste à injecter du SQL via des entrées (formulaire, barre d'adresse ...) pour prendre le contrôle de la base de données ainsi récupérer toutes données souhaitées par l'attaquant -(CLARHAUT, 2015)
- Man in the middle : attaque qui permet à l'attaquant d'écouter le réseau d'une victime (Steinberg, 2019).

Attaques coté serveur :

- Rançongiciel ou ransomware : type d'attaque la plus récente qui consiste à chiffrer un système d'informations puis d'envoyer une rançon au propriétaire souvent qui doit être payée en bitcoins (Steinberg, 2019).
- Vers informatique ou Worms : une attaque de type Worms peut avoir plusieurs impacts selon la véracité du vers et sa fonction première qui gravite autour de la subtilisation, le chiffrement, la copie, la modification et/ou la destruction des données. Le plus connu à ce jour, le trojan ou cheval de Troie (Steinberg, 2019).

Social engineering ou attaque par ingénierie sociale :

Ce type d'offensif est plus social, plus humain, car derrière tous ces termes barbares se trouve l'individu, l'utilisateur qui est détenteur de la plus grande faille ou vulnérabilité, souvent réaliser pendant la phase de reconnaissance et d'exploitation, elle consiste d'étudier l'homme avant la machine, son comportement, ses habitudes, son cercle social, toutes informations sont prises en compte par l'attaquant pour réaliser son cybercrime méticuleusement et efficacement (Steinberg, 2019).

La cyberattaque est très complexe à réaliser au même titre qu'une attaque militaire : la planification et la réalisation de chaque phase doivent être étudiées et optimisées au maximum pour la réussite de l'action, elle peut être offensive comme défensive. Mais quels sont les boucliers face à une telle épée ?

III. Leviers de protection des données sensibles contre les cyberattaques par les gouvernements

A. Les normes et les réglementations

Pour parer les actions cyber malicieuses, les gouvernements mettent en place des normes et des réglementations afin de prévenir, de sensibiliser et d'informer les utilisateurs sur leurs façons d'utiliser internet. Les réglementations varient selon les pays, voici une liste non exhaustive des règlements mis en place par des gouvernements :

- Convention du Conseil de l'Europe sur la cybercriminalité (également connue sous le nom de Convention de Budapest) :
_Il s'agit du premier accord international traitant de la criminalité informatique et de la cybercriminalité, y compris les cyberattaques. Le traité crée un cadre juridique et promeut la coopération internationale pour prévenir, enquêter et combattre la criminalité informatique (CLARHAUT, 2015).
- Directive de l'Union européenne sur la sécurité des réseaux et de l'information (NIS) :
_La directive NIS a été adoptée par l'Union européenne en 2016 et vise à renforcer la cybersécurité dans l'ensemble de l'UE. Elle oblige les États membres à prendre des mesures pour améliorer la sécurité des infrastructures critiques et des services numériques essentiels (CLARHAUT, 2015).
- Stratégie nationale de cybersécurité :
_De nombreux pays ont élaboré leurs propres stratégies nationales de cybersécurité pour faire face à la menace des cyberattaques. Ces stratégies fournissent des orientations et des actions concrètes pour protéger les infrastructures essentielles, les systèmes gouvernementaux et les entreprises (Priol, 2017).
- Loi sur la protection des données :
_De nombreuses juridictions ont des lois sur la confidentialité telles que le Règlement général sur la protection des données (RGPD) de l'Union européenne. Ces réglementations exigent des organisations qu'elles prennent les mesures appropriées pour protéger les données personnelles et signaler les failles de sécurité en temps opportun.
- Cadre de conformité et de certification :
_Certains pays ont établi des cadres de conformité et de certification en matière de cybersécurité. Par exemple, les États-Unis disposent du cadre de cybersécurité du National Institute of Standards and Technology (NIST) qui fournit des conseils sur la manière d'évaluer et d'améliorer la cybersécurité des infrastructures critiques (Priol, 2017).

B. Les politiques et les stratégies

Les stratégies et politiques, tout comme les normes et réglementations varient selon le pays. Voici quelques exemples :

- Stratégie nationale de cybersécurité : les différents pays élaborent des stratégies nationales de cybersécurité pour définir leur approche en matière de protection contre les cyberattaques.
- Coopération internationale : permet au différent état de coopérer pour lutter contre les cybermenaces (partage d'informations, enquêtes...).

- Protection des infrastructures critiques : élaborer un budget permettant de sécuriser optimalement les infrastructures.
- Sensibilisation et éducation : Les politiques de cybersécurité instaurent la sensibilisation et l'éducation pour encourager de bonnes pratiques de cybersécurité. (Formations, information, sensibilisation et prévention).
- Collaboration publique-privée : collaboration des politiques de la cybersécurité et des acteurs qui gravitent autour (organisme d'état, entreprise, recherche et développement)

C. Les technologies de cybersécurité

La cybersécurité est cruciale pour protéger nos informations et systèmes informatiques contre les attaques en ligne. Elle utilise différentes technologies telles que les pare-feux, la détection des intrusions, la cryptographie, l'authentification à deux facteurs, les analyses antivirus, les VPN et les tests d'intrusion. Ces technologies nous aident à filtrer le trafic, détecter les attaques, chiffrer les données, vérifier l'identité, éliminer les logiciels malveillants, sécuriser les communications et identifier les vulnérabilités. En combinant ces méthodes, nous renforçons notre sécurité en ligne.

Type de technologie	Descriptif
Pare-feu (Firewall)	Un pare-feu est un dispositif de sécurité réseau qui contrôle et filtre le trafic entrant et sortant d'un réseau, en se basant sur un ensemble de règles préétablies. Il permet de protéger les systèmes internes contre les attaques externes et les accès non autorisés.
Système de détection et de prévention des intrusions (IDS/IPS)	Les systèmes de détection et de prévention des intrusions surveillent le trafic réseau à la recherche de schémas et de comportements suspects. Ils détectent les tentatives d'intrusion et prennent des mesures pour les bloquer ou les prévenir, protégeant ainsi le réseau contre les attaques.
Cryptographie	La cryptographie est l'art de protéger l'information en la transformant à l'aide d'algorithmes mathématiques. Elle est utilisée pour chiffrer les données, assurer leur confidentialité et leur intégrité lorsqu'elles sont stockées ou transmises.
Système de gestion des informations et des événements de sécurité (SIEM)	Un SIEM collecte, analyse et corrèle les informations provenant de différents systèmes et dispositifs de sécurité pour détecter les menaces et les activités suspectes. Il permet une gestion centralisée des journaux de sécurité et une réponse efficace aux incidents (Steinberg, 2019).

Authentification à deux facteurs (2FA)	L'authentification à deux facteurs renforce la sécurité des comptes en exigeant deux éléments distincts pour vérifier l'identité d'un utilisateur. Cela peut inclure un mot de passe suivi d'un code généré par une application mobile ou envoyé par SMS (Steinberg, 2019).
Analyse antivirus et antimalware	Les logiciels antivirus et antimalware sont conçus pour détecter, prévenir et éliminer les logiciels malveillants tels que les virus, les vers, les chevaux de Troie et les logiciels espions. Ils effectuent une analyse des fichiers et du système à la recherche de codes malveillants (Steinberg, 2019).
Virtual Private Network (VPN)	Un VPN crée un tunnel sécurisé entre un appareil et un réseau privé, en chiffrant les données qui y transitent. Il permet de protéger la confidentialité des communications et d'accéder de manière sécurisée à des réseaux distants sur Internet (CLARHAUT, 2015).
Tests d'intrusion (Penetration testing)	Les tests d'intrusion sont des évaluations de sécurité réalisées par des professionnels de la cybersécurité pour identifier les vulnérabilités et les failles dans un système ou un réseau. Ils simulent des attaques pour aider à renforcer la sécurité et à prévenir les intrusions réelles (Steinberg, 2019).

Ce tableau fournit un aperçu de quelques technologies couramment utilisées en cybersécurité, mais il en existe bien d'autres. Chaque technologie joue un rôle important dans la protection des systèmes et des données contre les menaces informatiques.

Internet étant en constante évolution, les normes, les réglementations, les stratégies, les politiques et les technologies évoluent sans cesse et s'adaptent au fil du temps.

Conclusion

En conclusion, il est essentiel de comprendre la nature des données sensibles et la distinction entre les données personnelles et sensibles. Toutes les données sensibles sont des données personnelles, mais toutes les données personnelles ne sont pas nécessairement sensibles. Les données sensibles, telles que les informations bancaires, les données biométriques, les données géospatiales et les opinions politiques et religieuses, nécessitent une protection adéquate en raison de leur nature et du risque qu'elles peuvent poser si elles sont compromises.

Il est également crucial de considérer les différentes formes de stockage des données sensibles. Les entreprises, les gouvernements et les fournisseurs de services cloud utilisent diverses méthodes de stockage, telles que le stockage sur site, le stockage sur service cloud privé ou public, et le stockage hybride. Chacune de ces formes de stockage présente ses propres avantages et inconvénients en termes de contrôle des données et de sécurité.

Cependant, il est important de noter que le stockage sécurisé des données sensibles pose également des défis environnementaux. Les data centers et autres équipements de stockage sont très énergivores et peuvent contribuer à la pollution. Il est donc essentiel de trouver un équilibre entre la sécurité des données sensibles et la durabilité environnementale.

En ce qui concerne la prévention des cyberattaques, il est crucial de mettre en place des normes et des réglementations pour sensibiliser et informer les utilisateurs sur les meilleures pratiques de sécurité. Les gouvernements du monde entier ont mis en place des réglementations telles que la Convention du Conseil de l'Europe sur la cybercriminalité et la directive de l'Union européenne sur la sécurité des réseaux et de l'information. De plus, les stratégies nationales de cybersécurité et les lois sur la protection des données jouent un rôle essentiel dans la protection des données sensibles.

En fin de compte, la protection des données sensibles et la prévention des cyberattaques exigent une approche globale qui implique la sensibilisation, la réglementation, la technologie et la collaboration entre les différents acteurs. Il est essentiel de reconnaître l'importance de la sécurité des données sensibles dans un monde de plus en plus connecté et de prendre des mesures anticipatrices pour prévenir les atteintes à la vie privée et les conséquences potentiellement dommageables des cyberattaques.

Bibliographie

Arte (Réalisateur). (2023, mai). *Pegasus, un espion dans votre poche* [Film]. Récupéré sur Youtube.

CLARHAUT, J. (2015). *Cyberdéfense : la sécurité de l'informatique industrielle*. Edition ENI.

CNIL. (2023). *rgpd de quoi parle t on* . Récupéré sur cnil.fr: <https://www.cnil.fr/fr/rgpd-de-quoi-parle-t-on>

Dumons, o. (2014). Internet, la pollution cachée. *Le Monde*.

Priol, J. (2017). *Big data des territoires* . éditions FYP.

Steinberg, J. (2019). *la cybersécurité pour les nuls*. éditions First.

Wikipédia. (2023). *wiki/Cyberattaque*. Récupéré sur Wikipédia:
<https://fr.wikipedia.org/wiki/Cyberattaque>